

Tableau de Bord Sécurité — KRI & KPI — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Statut : Validé
Fréquence de mise à jour : Mensuelle (KRI) / Trimestrielle (KPI)
Destinataires : CODIR, DSI, DPO

Principe de pilotage

TABLEAU DE BORD SÉCURITÉ TECHSHOP SAS
TABLEAU DE BORD SÉCURITÉ TECHSHOP SAS

KRI (Risques)	SMSI	KPI (Performance)
Signaux d'alerte -> "ça va mal se passer si..."	Décisions DSI -> + CODIR	Efficacité des actions -> "Nos mesures fonctionnent-elles ?"
Fréquence : mensuelle		Fréquence : trimestrielle

Règle des seuils :

Couleur	Signification	Action
[OK] Vert	Dans la cible — situation normale	Surveillance standard
[MODERE] Jaune	Seuil d'alerte atteint — vigilance	DSI informe le CODIR
[CRITIQUE] Rouge	Seuil critique dépassé — danger	Action corrective immédiate + escalade DG

KRI — Key Risk Indicators (8 indicateurs)

Les KRI mesurent l'exposition au risque en temps réel. Un KRI rouge signifie qu'un risque identifié dans le registre est en train de se matérialiser.

KRI-01 — Comptes sans MFA (lié à R03)

Champ	Détail
Description	Pourcentage de comptes utilisateurs actifs (Google Workspace + Odoo + AWS) sans authentification multi-facteurs activée
Formule	$(\text{Nombre de comptes sans MFA} / \text{Nombre total de comptes actifs}) \times 100$
Source de données	Google Workspace Admin Console -> Rapports -> Sécurité -> Authentification en 2 étapes
Fréquence	Mensuelle
Cible	0% (aucun compte sans MFA)
Seuil alerte [MODERE]	> 5% (plus de 2 comptes sur 47)
Seuil critique [CRITIQUE]	> 20% (plus de 9 comptes)
Valeur juin 2026	[CRITIQUE] 98% (46 comptes sur 47 sans MFA)
Risque associé	R03 — Compromission compte GW Admin (criticité 12/16)
Responsable	DSI — Thomas Rivet

KRI-02 — CVE critiques non patchées (lié à R06, R15)

Champ	Détail
Description	Nombre de vulnérabilités critiques (CVSS ≥ 9.0) identifiées sur WooCommerce/WordPress non corrigées au-delà du délai politique (72h)
Formule	Nombre de CVE CVSS ≥ 9.0 avec ancienneté > 72h dans le parc WordPress
Source de données	Rapport WPScan mensuel (poc/wpscan/) + NVD (nvd.nist.gov)
Fréquence	Mensuelle (WPScan automatisé)
Cible	0 CVE critique non patchée au-delà de 72h
Seuil alerte [MODERE]	≥ 1 CVE critique > 72h non patchée
Seuil critique [CRITIQUE]	≥ 3 CVE critiques ou ≥ 1 CVE critique > 7 jours
Valeur juin 2026	[MODERE] 2 CVE (plugins WooCommerce Payments v5.6 + Contact Form 7)
Risque associé	R06 (SQLi), R15 (défacement)
Responsable	DSI — Thomas Rivet

KRI-03 — Jours depuis le dernier test de restauration (lié à R11)

Champ	Détail
Description	Nombre de jours écoulés depuis le dernier test de restauration complet des sauvegardes (BDD WooCommerce + Odoo)
Formule	Date du jour – Date du dernier test de restauration documenté
Source de données	Registre des tests de restauration (à créer — M07)
Fréquence	Mensuelle
Cible	≤ 90 jours (test trimestriel)
Seuil alerte [MODERE]	> 90 jours
Seuil critique [CRITIQUE]	> 180 jours OU aucun test réalisé
Valeur juin 2026	[CRITIQUE] Jamais testé — aucun test formel réalisé depuis la création de TechShop
Risque associé	R11 (backup corrompu), R01 (ransomware sans PRA)
Responsable	DSI — Thomas Rivet

KRI-04 — Transferts de données hors UE non conformes (lié à R07)

Champ	Détail
Description	Nombre de flux de données vers des pays hors UE sans mécanisme de transfert RGPD valide (SCC, DPF, BCR)
Formule	Nombre de destinataires hors UE dans le registre des traitements sans DPA/SCC documenté
Source de données	Registre des traitements RGPD (smsi/06-controles-nis2-rgpd/rgpd-conformite.md)
Fréquence	Mensuelle
Cible	0 flux non conforme
Seuil alerte [MODERE]	≥ 1 flux non conforme impliquant des données peu sensibles
Seuil critique [CRITIQUE]	≥ 1 flux non conforme impliquant des données clients ou RH
Valeur juin 2026	[CRITIQUE] 2 flux non conformes (AWS us-east-1 + HubSpot Free)
Risque associé	R07 (non-conformité RGPD)
Responsable	DPO — Sophie Blanc

KRI-05 — Comptes orphelins (ex-employés) (lié à R05)

Champ	Détail
Description	Nombre de comptes actifs (Google Workspace, Odoo, AWS IAM) appartenant à des personnes n'étant plus en poste chez TechShop

Champ	Détail
Formule	Nombre de comptes actifs dont le titulaire n'est plus dans la liste RH active
Source de données	Croisement liste RH (Odoo HR) × comptes GW Admin Console + IAM AWS
Fréquence	Mensuelle
Cible	0 compte orphelin
Seuil alerte [MODERE]	≥ 1 compte orphelin
Seuil critique [CRITIQUE]	≥ 1 compte orphelin avec droits d'administration
Valeur juin 2026	[MODERE] 3 comptes (2 GW + 1 Odoo — anciens employés 2024-2025)
Risque associé	R05 (accès non autorisé Odoo)
Responsable	DSI — Thomas Rivet

KRI-06 — Taux de clics phishing simulé (lié à R10)

Champ	Détail
Description	Pourcentage d'employés ayant cliqué sur un lien dans un email de phishing simulé lors des exercices périodiques
Formule	(Nombre de clics / Nombre d'employés ciblés par la simulation) × 100
Source de données	Rapport GoPhish (simulation trimestrielle)
Fréquence	Trimestrielle
Cible	< 5% (benchmark secteur PME formée)
Seuil alerte [MODERE]	5% – 20%
Seuil critique [CRITIQUE]	> 20%
Valeur juin 2026	[CRITIQUE] Non mesuré — aucune simulation réalisée (formation M08 non encore déployée)
Risque associé	R10 (malware via phishing)
Responsable	DSI + RH

KRI-07 — Disponibilité des services critiques (lié à R08)

Champ	Détail
Description	Taux de disponibilité mensuel des services critiques : WooCommerce (site e-commerce) et Odoo (ERP)
Formule	(Temps disponible / Temps total du mois) × 100 — par service

Champ	Détail
Source de données	Grafana + Prometheus (supervision OVH) + UptimeRobot (externe)
Fréquence	Mensuelle (collecte en continu)
Cible	$\geq 99.5\%$ ($\leq 3h36$ d'indisponibilité/mois)
Seuil alerte [MODERE]	99.0% – 99.5%
Seuil critique [CRITIQUE]	$< 99.0\%$ ($> 7h12$ d'indisponibilité/mois)
Valeur juin 2026	[OK] WooCommerce 99.7% / Odoo 99.8%
Risque associé	R08 (panne serveurs OVH)
Responsable	DSI — Thomas Rivet

KRI-08 — Alertes WAF bloquées (lié à R02, R06)

Champ	Détail
Description	Nombre d'attaques bloquées par Cloudflare WAF par mois — indicateur de la pression d'attaque sur le site
Formule	Nombre d'événements WAF avec action "Block" dans le dashboard Cloudflare
Source de données	Cloudflare Dashboard -> Security -> WAF -> Activity log
Fréquence	Mensuelle
Cible	Baseline à établir sur 3 mois. Alerte sur variation $> +200\%$ vs baseline
Seuil alerte [MODERE]	$+200\%$ vs baseline mensuelle (pic d'attaque)
Seuil critique [CRITIQUE]	Attaque ciblée détectée (même IP, même payload, > 1000 req/min)
Valeur juin 2026	[MODERE] 847 blocages (baseline en cours d'établissement — WAF en mode Log, pas encore Block)
Risque associé	R02 (fuite données), R06 (injection SQL)
Responsable	DSI — Thomas Rivet

KPI — Key Performance Indicators (6 indicateurs)

Les KPI mesurent l'efficacité du programme de sécurité. Ils répondent à la question : "Est-ce que nos investissements sécurité produisent des résultats ?"

KPI-01 — Couverture MFA

Champ	Détail
Description	Pourcentage de comptes critiques avec MFA activé
Formule	$(\text{Comptes avec MFA} / \text{Total comptes actifs}) \times 100$
Source	GW Admin Console + AWS IAM + OVH Manager
Fréquence	Trimestrielle
Cible T3 2026	100%
Valeur juin 2026	[CRITIQUE] 2% (1/47)
Valeur cible sept. 2026	[OK] 100% (post M01)
Lié à	Mesure M01 du PTR

KPI-02 — Délai moyen de patch (MTTR vulnérabilités)

Champ	Détail
Description	Délai moyen entre la publication d'une CVE critique (CVSS ≥ 9.0) affectant le périmètre TechShop et son application du patch
Formule	$\text{Moyenne}(\text{Date patch} - \text{Date publication CVE})$ sur les CVE du trimestre
Source	WPScan + NVD + journal des mises à jour DSI
Fréquence	Trimestrielle
Cible	$\leq 72\text{h}$ pour CVE critique / ≤ 7 jours pour CVE élevé
Valeur juin 2026	[CRITIQUE] Non mesuré (politique patch non encore formalisée)
Valeur cible déc. 2026	[OK] $\leq 72\text{h}$
Lié à	Mesure M10 du PTR

KPI-03 — Taux de conformité SoA ISO 27001

Champ	Détail
Description	Pourcentage de contrôles ISO 27001 Annex A au statut "Implémenté" sur les 84 contrôles applicables
Formule	$(\text{Contrôles "Implémenté"} / 84 \text{ contrôles applicables}) \times 100$
Source	SoA ISO 27001 (smsi/04-declaration-applicabilite/SoA-iso27001.md)
Fréquence	Trimestrielle
Cible fin 2026	$\geq 30\%$ (de 10% à 30% en 6 mois)
Cible fin 2027	$\geq 60\%$ (niveau pré-certification)

Champ	Détail
Valeur juin 2026	[CRITIQUE] 10% (9/84 contrôles implémentés)
Valeur cible déc. 2026	[MODERE] 30%
Lié à	Programme SMSI global

KPI-04 — Taux d'employés formés à la sécurité

Champ	Détail
Description	Pourcentage d'employés ayant complété la formation sécurité annuelle obligatoire
Formule	$(\text{Employés avec attestation formation} / \text{Total employés}) \times 100$
Source	Registre de formation RH + émargements
Fréquence	Trimestrielle (puis annuelle une fois le programme stable)
Cible	100% avant le 31/10/2026
Valeur juin 2026	[CRITIQUE] 0% (aucune formation réalisée)
Valeur cible oct. 2026	[OK] 100% (post M08)
Lié à	Mesure M08 du PTR

KPI-05 — Conformité RGPD transferts hors UE

Champ	Détail
Description	Pourcentage de flux de données vers des pays hors UE couverts par un mécanisme légal RGPD valide (SCC, DPF, DPA signé)
Formule	$(\text{Flux hors UE conformes} / \text{Total flux hors UE identifiés}) \times 100$
Source	Registre des traitements RGPD
Fréquence	Trimestrielle
Cible	100% avant le 30/09/2026
Valeur juin 2026	[CRITIQUE] 29% (2 conformes sur 7 flux identifiés)
Valeur cible sept. 2026	[OK] 100% (post M02 + HubSpot)
Lié à	Mesures M02, NC-02

KPI-06 — Incidents de sécurité résolus dans les délais

Champ	Détail
Description	Pourcentage d'incidents de sécurité résolus dans les délais définis par leur niveau de priorité (P1 : 4h, P2 : 24h, P3 : 72h)
Formule	(Incidents résolus dans délai / Total incidents du trimestre) × 100
Source	Registre des incidents (poc/cnil/ + futur outil ticketing)
Fréquence	Trimestrielle
Cible	≥ 90%
Valeur juin 2026	[OK] 100% (0 incident réel — exercice CNIL simulé résolu dans les délais)
Note	Indicateur à réinterpréter dès le premier incident réel
Lié à	Procédure gestion incidents (NIS2 Art. 21b)

Tableau de Bord Synthétique — Juin 2026

Vue d'ensemble CODIR

TABLEAU DE BORD SÉCURITÉ - TECHSHOP SAS - JUIN 2026				
KRI - SIGNAUX D'ALERTE				
Indicateur	Stat	Valeur		
KRI-01 Comptes sans MFA		98% (46/47)		
KRI-02 CVE critiques non patchées		2 CVE actives		
KRI-03 Test backup (jours)		Jamais testé		
KRI-04 Transferts hors UE RGPD		2 flux / conf.		
KRI-05 Comptes orphelins		3 comptes		
KRI-06 Taux clic phishing simulé		Non mesuré		
KRI-07 Dispo services critiques		99.7% / 99.8%		
KRI-08 Alertes WAF bloquées		847/mois		
KPI - EFFICACITÉ DU PROGRAMME				
Indicateur	Stat	Valeur		
KPI-01 Couverture MFA		2% -> cible 100%		
KPI-02 MTR vulnérabilités		Non mesuré		
KPI-03 Conformité SoA ISO 27001		10% -> cible 30%		
KPI-04 Employés formés sécurité		0% -> cible 100%		
KPI-05 Transferts RGPD conformes		29% -> cible 100%		
KPI-06 Incidents résolus / temps		100% (0 réel)		
SCORE GLOBAL SÉCURITÉ : 28/100 <- SMSI en démarrage (normal)				
ACTIONS IMMÉDIATES (avant 31/07/2026) :				
1. Activer MFA tous comptes GW	(KRI-01, KPI-01)	07		
2. Migrer AWS S3 eu-west-3	(KRI-04, KPI-05)	1 jour		
3. Désactiver 3 comptes orphelins	(KRI-05)	2h		

??

Projection — Tableau de bord cible Décembre 2026

Après déploiement des mesures M01 à M10 du Plan de Traitement :

KRI-01 Comptes sans MFA	?	8%	(298 points)
KRI-02 CVE non patchés	?	0	(72)
KRI-03 Test backup	?	2 00j	(premier test réalisé)
KRI-04 Transferts à RGPD	?	0	(22 flux)
KRI-05 Comptes orphelins	?	0	(73)
KRI-06 Clic phishing	?	-15%	(premier exercice, avant formation)
KPI-01 Couverture MFA	?	100%	
KPI-03 Conformité SoA	?	30%	
KPI-04 Employés formés	?	100%	
KPI-05 Transferts RGPD	?	100%	

Score global estimé déc. 2026 : 62/100 (+34 points en 6 mois)

Fréquences et responsabilités

Indicateur	Fréquence	Collecte	Reporting
KRI-01 à KRI-06	Mensuelle	DSI	Tableau de bord DSI
KRI-07	Continue	Grafana auto	Alerte automatique
KRI-08	Mensuelle	Cloudflare	Tableau de bord DSI
KPI-01 à KPI-06	Trimestrielle	DSI + DPO	CODIR trimestriel
Tableau de bord synthétique	Trimestrielle	DSI	Présentation CODIR

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine mise à jour : Septembre 2026 (fin T3)